

- Threat Hunt Generation Report: From PostCSS Masquerading to Windows RAT | JFrog
 - Executive Summary
 - Threat Actors
 - PostCSS-Loader Attack
 - Campaigns
 - Package-Impersonation Attack
 - Malware
 - Windows RAT (RAT)
 - Windows RAT Payload (Backdoor)
 - Indicators of Compromise
 - Observed Behaviors
 - MITRE ATT&CK Mapping
 - PEAK Hunt Hypotheses
 - Hunt 1
 - Prepare
 - Execute
 - Act
 - Hunt 2
 - Prepare
 - Execute
 - Act

Threat Hunt Generation Report: From PostCSS Masquerading to Windows RAT | JFrog

Field	Value
Source	research.jfrog.com
Published	2026-06-22 00:00 UTC
URL	https://research.jfrog.com/post/from-postcss-typosquat-to-windows-rat/
Classification	Security Incident
Report Generated	2026-06-25 09:56 UTC
Model	cth-qwen:latest
LLM Processing Time	2602.75s

Executive Summary

A malicious npm package named postcss-minify-selector-parser masqueraded as a legitimate tool, leading to a Windows RAT with capabilities including remote shell execution, file transfer, persistence, and Chrome credential theft. The infection chain involved a PowerShell downloader and a Python-based payload, with C2 communication directed to 95.216.92.207.

Threat Actors

PostCSS-Loader Attack

- **Aliases:** —
- **Motivation:** Steal browser credentials and sensitive data via compromised npm packages
- **Evidence:** Malware references Chrome decryption APIs (DPAPI, NCryptDecrypt), Chrome profile files (Local State/Login Data), and VM detection checks

Campaigns

Package-Impersonation Attack

- **Aliases:** —
- **Description:** Exploits legitimate npm package names to deliver multi-stage Windows payloads, masquerading as build tools with high weekly usage
- **Evidence:** Packages like postcss-minify-selector-parser act as entry points, with real payloads delivered via embedded loaders and PowerShell stages

Malware

Windows RAT (RAT)

- **Aliases:** —
- **Description:** Capable of remote shell execution, file transfer, persistence via registry, Chrome extension data collection, and saved-login theft. Orchestrated via a Python-based payload with encrypted C2 communication.

Windows RAT Payload (Backdoor)

- **Aliases:** —
- **Description:** Multi-stage malware using encrypted C2 communication, VM detection, and Chrome credential theft via Python modules (auto.pyd, command.pyd). References Chrome encryption logic (AES.MODE_GCM, ChaCha20_Poly1305) and Windows APIs (SeDebugPrivilege).

Indicators of Compromise

IOC Value	Type	Context
nvidiadriv[.]net	Domain	Used by the PowerShell downloader to fetch payloads

IOC Value	Type	Context
95.216.92.207	IP Address	C2 server for the RAT; C2 IP address used for encrypted communication
winpatch-xd7d.win	Filename	Payload file downloaded by the PowerShell downloader
update.vbs	Filename	VBS script executed to initiate the Python loader
dll.zip	Filename	Archived Python modules extracted by the loader
HKCU\Software\Microsoft\Windows\CurrentVersion\Run	Registry Key	Modified for persistence by the RAT
powershell -NoProfile -ExecutionPolicy Bypass -File ../../settings.ps1	URL	Encoded PowerShell command to download payloads
wscript "\$env:TEMP\winPatch\update.vbs"	URL	VBS command to execute the Python loader
nvidiadrivernet	Domain	C2 domain used for payload delivery and command-and-control
hxxp[:]//nvidiadrivernet[.]net/verv1432/winpatch-xd7d[.]win	URL	Malicious URL for payload delivery
hxxp[:]//95[.]216[.]92[.]207:8080	URL	Encrypted C2 communication endpoint
%TEMP%\winPatch.zip	Filename	Temporary file used for payload extraction
%TEMP%\winPatch\update.vbs	Filename	VBScript used for payload execution
%TEMP%.store	Filename	Temporary directory for malware operations
%TEMP%.host	Filename	Temporary directory for malware operations
HKCU\Software\Microsoft\Windows\CurrentVersion\Run\csshost	Registry Key	Persistence mechanism for malware

IOC Value	Type	Context
win-driver-xd7d/chost.exe	Filename	Executable loader for the malware
win-driver-xd7d/loader.py	Filename	Python script for payload execution
win-driver-xd7d/api.cp310-win_amd64.pyd	Filename	Python module for C2 communication
win-driver-xd7d/auto.cp310-win_amd64.pyd	Filename	Module for Chrome credential theft
win-driver-xd7d/command.cp310-win_amd64.pyd	Filename	Module for VM detection and host profiling
win-driver-xd7d/config.cp310-win_amd64.pyd	Filename	Configuration module for malware
win-driver-xd7d/util.cp310-win_amd64.pyd	Filename	Utility module for malware operations
164e322d6fbc62e254d73583acd7f39444c884d3f5e6a5d27db143fc25bc88b3	URL	Hash for win-driver-xd7d/audiodriver.cp310-win_amd64.pyd
50ffce607867d8fa8eaf6ef5cd25a3c0e7e4415e881b9e55c04a67bcddb74fdf	URL	Hash for win-driver-xd7d/api.cp310-win_amd64.pyd
17832aa629524ef6e8d8d6e9b6b902a8d324b559e3c36dbd0e221ab1690be871	URL	Hash for win-driver-xd7d/auto.cp310-win_amd64.pyd
c8075bbff748096e1c6a1ea0aa67bb6762fdd7551427a12425b35b94c1f1ecf2	URL	Hash for win-driver-xd7d/command.cp310-win_amd64.pyd
f6669bd504ce6b0e303be7ee47f2ebbc062989c88c41f0a3f436044a24869798	URL	Hash for win-driver-xd7d/config.cp310-win_amd64.pyd
282b9bc3182b9bc3182b9bc3182b9bc3182b9bc3182b9bc3182b9bc3182b9bc3	URL	Hash for win-driver-xd7d/util.cp310-win_amd64.pyd

Observed Behaviors

1. PowerShell executed with encoded command to download payload from C2

- **Evidence:** PowerShell command to fetch payloads from nvidiadriv[.]net
- **Artifacts:** powershell -NoProfile -ExecutionPolicy Bypass -File ../../settings.ps1, nvidiadriv[.]net

- **Context:** Initial stage of the infection chain

2. Registry HKCU\Software\Microsoft\Windows\CurrentVersion\Run modified for persistence

- **Evidence:** RAT added persistence via registry key
- **Artifacts:** HKCU\Software\Microsoft\Windows\CurrentVersion\Run
- **Context:** Established long-term access

3. C2 communication over HTTP with encrypted packets

- **Evidence:** RAT used HTTP C2 with encrypted message exchange
- **Artifacts:** 95.216.92.207
- **Context:** Orchestrated command execution and data exfiltration

4. File upload/download via C2 packet protocol

- **Evidence:** RAT handled file transfers using C2 communication
- **Artifacts:** 95.216.92.207
- **Context:** Exfiltrated stolen data and executed remote commands

5. Chrome credential theft via auto.pyd module

- **Evidence:** auto.pyd module collected Chrome saved-logins
- **Artifacts:** auto.pyd
- **Context:** Targeted credential harvesting

6. Python loader executed to decompress and run malware

- **Evidence:** VBS script initiated Python-based payload decomposition
- **Artifacts:** dll.zip, update.vbs
- **Context:** Decompression of modular malware components

MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Observed Behavior
Execution	T1059.001	Command and Scripting Interpreter: PowerShell	PowerShell executed with encoded command to download payload from C2
Persistence	T1112	Modify Registry	Registry HKCU\Software\Microsoft\Windows\CurrentVersion\Run modified f
Command and Control	T1102.003	Web Service: One-Way Communication	C2 communication over HTTP with encrypted packets
Command and Control	T1071.002	Application Layer Protocol: File	File upload/download via C2 packet protocol

Tactic	Technique ID	Technique Name	Observed Behavior
		Transfer Protocols	
Credential Access	T1555.003	Credentials from Password Stores: Credentials from Web Browsers	Chrome credential theft via auto.pyd module
Stealth	T1027.002	Obfuscated Files or Information: Software Packing	Python loader executed to decompress and run malware

PEAK Hunt Hypotheses

Hunt 1

Prepare

- **Hypothesis:** Adversaries may be using PowerShell to download payloads from nvidiadrivernet for initial compromise.
- **Behavior Basis:** PowerShell executed with encoded command to download payload from nvidiadrivernet
- **Objective:** Validate if the PowerShell command is executing remote payloads and establishing command and control.
- **Required Data Sources:** PowerShell execution logs, Network connection telemetry

Execute

Gather Data

- Collect PowerShell execution events with the command 'powershell -NoProfile -ExecutionPolicy Bypass -File ../../settings.ps1'
- Correlate process creation events with outbound connections to 'nvidiadrivernet'

Analysis Steps

- Check if the PowerShell script contains obfuscated commands or download logic
- Verify if the domain 'nvidiadrivernet' is resolving to the observed IP 95.216.92.207

Supporting Evidence

- Presence of the encoded PowerShell command in execution logs
- Outbound HTTP connections to nvidiadrivernet or 95.216.92.207

Act

- **Documentation Requirements:** Record the PowerShell command, associated IP/domain, and any decrypted payload artifacts.

Findings to Preserve

- Encoded PowerShell script artifacts
- Network connection timestamps to nvidiadriv[.]net

Future Hunt Recommendations

- Monitor for similar PowerShell scripts with encoded commands
- Track domain generation algorithm (DGA) patterns for nvidiadriv[.]net

Hunt 2

Prepare

- **Hypothesis:** Adversaries may be establishing persistence via the HKCU\Software\Microsoft\Windows\CurrentVersion\Run registry key.
- **Behavior Basis:** Registry HKCU\Software\Microsoft\Windows\CurrentVersion\Run modified for persistence
- **Objective:** Validate if the registry key is used to maintain long-term access to the environment.
- **Required Data Sources:** Registry change telemetry, Process creation logs

Execute

Gather Data

- Extract registry modifications to HKCU\Software\Microsoft\Windows\CurrentVersion\Run
- Check if the registry key is used to launch processes at system startup

Analysis Steps

- Verify if the registry key contains references to malicious executables or scripts
- Cross-reference with process creation events to identify persistence mechanisms

Supporting Evidence

- Registry key modifications matching the observed artifacts
- Scheduled process execution tied to the registry key

Act

- **Documentation Requirements:** Document the registry key contents and associated process execution patterns.

Findings to Preserve

- Registry key modification artifacts
- Process execution timestamps for persistence

Future Hunt Recommendations

- Monitor for registry key modifications in other user-specific locations
- Track execution of scripts or executables from the Run key

Generated by Threat Hunt Generation Pipeline | 2026-06-25 09:56 UTC